CIBERSEGURANÇA

<1> INFORMAÇÕES GERAIS

O que faz?
- Protege contra ataques e Danos, garantindo segurança nas informações ou processos

3 Pilares -CID-
- Confidencialidade: Os dados apenas podem ser acessados por alguém com acesso permitido.
- Integridade: Os dados não sofreram modificações ou exclusões indesejadas.
- Disponibiliade: Os dados estão disponíveis sempre que for preciso.

OS e Ferramentas de código
- Windows: PowerShell/CMD
Mais utilizado em empresas.
Malwares em sua maioria são feitos para atacar ele
Blue Team (Defesa) Red Team (Ataque)

- MacOS: Unix-like
Muito seguro, pois utiliza código baseado em Unix
Possíveis adaptações

- Linux: Bash/ZSH/PowerShell
Open Source
100% Personalizável
Muito seguro

Gerenciamento de Risco
- Como gerenciar o risco?
Vamos supor que eu esteja numa região com vários assaltos de veículos. Como eu posso gerenciar o risco?

1- Eliminar o Risco.
EX: Sem carro, sem carro roubado

2- Mitigar o Risco.
EX: Andar menos de carro

3- Aceitar o Risco.
EX: Fodase se posso ser roubado

4- Transferir o Risco.
EX: Faço um seguro e eles que se virem se roubarem meu carro

OBS: O risco é algo a sempre ser revisto, pois todo ativo tem risco e eles sempre mudam

O que é "Risco"?
- Probabilidade de algo acontecer ou Causar um acidente, algo que vai gerar um
----------------IMPACTO----------------------

PLANEJAR → EXECUTAR → CHECAR → AGIR

Como avaliar o Impacto?
- Para avaliar o impacto do risco primeiro devemos ver qual o valor dessa informação ou ativo para a empresa

Plano de Ação
- Após a avaliação do risco é a hora de montar um plano de ação (ou plano de cibersegurança), esse plano não tem um padrão pré definido, ele vai ser criado assim que a empresa mapear os riscos, ameaças e vulnerabilidades

OBS: Cada plano é criado diferente pois o mesmo "Ativo" é diferente para cada empresa, caso uma KPMG fique sem internet isso gera uma perda gigante, porém, caso o shopping fique sem a internet pública fodase ninguém usa aquela bosta

5 Fases
1- Identificação
2- Proteção
3- Detecção
4- Resposta
5- Recuperação

<2> MAPEAMENTO DE REDE

HOST SCAN — PORT SCAN — SERVICE SCAN

Ferramentas de mapeamento de rede
OBS: Todos são um tipo de VARREDURA

HOST SCAN
- Verifica todos os dispositivos conectados a rede (Puxa via IP)

PING/FPING
Utilizados para descobrir os host ativos, dessa forma conseguimos analizar a conectividade de uma máquina (PING individual, FPING geral)

NMAP
Verificação melhor que o FPING, pois além de mostrar os dispositivos ativos, também mostra os desligados

Opções de NMAP
- Individual
Analise de apenas um endereço
- Coletivo
Analise de toda a rede
- Faixa
Analise em uma faixa específica

OBS: NMAP é o PING com esteroides e mais personalizável

PORT SCAN
- Identificação de portas ativas e o que está ligado

TCP CONNECT SCAN
Lento e pouco utilizado, é individual e é considerado pouco furtivo (pois analisa de porta em porta

TCP SYN SCAN
Mais rápido, apenas sincroniza com a rede e vai embora, apenas enviar "sim" ou "não" da porta

UDP SCAN
Joga o pacote (ML) se respondeu ta ligado, se não respondeu ta desligado (Pouco confiável, mas ta ai)

SERVICE SCAN
- Identificação dos serviços ativos (Utilizando NMAP)

Podemos ver as portas e o que está rodando nelas, assim como a versão que está sendo utilizada, dessa forma conseguimos atualizar antes de surgir uma vulnerabilidade

OS-FINGERPRINT
Utilizado para a visualização do OS (Sistema Operacional) e sua versão

VARREDURA (SCAN NMAP)
Default -> Tudo ativo e não mostra vulnerabilidade

VULN
Mostra as vulnerabilidades assim como o dispositivo com essa falha

FASES PENTEST

1- HOST SCAN
O que está ligado a rede

2- PORT SCAN
Quais portas TCP e UDP estão abertas

3- SERVICE SCAN/OS FINGERPRINT
Quais serviços do servidor e OS (Sistema Operacional)

4- ANÁLISE DE VULNERABILIDADE
Cruzar os dados dos serviços/versões encontrados nas fases anteriores com bancos de dados de falhas conhecidas (CVEs)

<3> TIPOS DE ATAQUES E ATAQUES COMUNS

Buffer Overflow
Cria instruções para encher a memória e quando ele for buscar mais memória ele é direcionado para um ponteiro de código malicioso. Dessa forma o atacante consegue se conectar no BIND SHELL ou REVERSE SHELL

- BIND SHELL: O Atacante envia o código para a máquina e se conecta com a porta aberta no servidor
- REVERSE SHELL: O Atacante envia o código porém é o servidor que vai conectar com a porta aberta do atacante

DOS
Feito a partir de uma única máquina, utiliza-se da negação do serviço

SYN FLOOD
Várias máquinas tentam entrar em sincronia com o servidor, porém ela não envia o "OK" de volta para o servidor, fazendo ele sobrecarregar de tanta solicitação

DDOS
Feito a partir de diversas máquinas (Efeito Zumbi)

UDP REFLECTION
É enviado um pacote falso, que é re-transmitido para o servidor alvo

ATAQUES DE ENGENHARIA SOCIAL
- Intimidação
- Persuasão
- Bajulação
- Assistência à vítima

PHISHING
Email ou Mensagem feita para enganar ou assustar o alvo
EX: O alvo recebe um email dizendo que sua conta no banco está compromentida e apenas clicando naquele link ele vai conseguir recuperar o acesso

SPEAR PHISHING
Utiliza-se da cópia das informações de uma vítima para atacar outra.
EX: Receber uma mensagem de um amigo que mudou de número e precisa de dinheiro naquele momento

<4> MALWARES

TIPOS

Trojan (Cavalo de Troia):
- Finge ser um programa legítimo (como um instalador falso ou aquele produto não oficial) para abrir portas (backdoors) no sistema sem a pessoa perceber.

Worm (Verme):
- Diferente do vírus comum, ele não precisa que o usuário clique em nada. Ele se espalha automaticamente pela rede explorando vulnerabilidades (lembra daquela falha que o Vulnerability Scan acha? É por aí que o Worm entra).

Ransomware:
- O mais famoso hoje. Ele sequestra a máquina, criptografa os arquivos da vítima e exige um pagamento (geralmente em Bitcoin) pelo resgate.

Spyware & Keylogger:
- Focados em espionagem. O Keylogger grava tudo o que é digitado no teclado para roubar senhas.

Cryptominer (ou Cryptojacking):
- Fica escondido minerando criptomoedas para o atacante usando os recursos da sua máquina.

PRECAUÇÕES
- Utilizar um antivírus (Windows Defender, Kaspersky)
- Evitar utilizar produtos não oficiais (👀)
- Verificar links suspeitos no VírusTotal
- Não instalar arquivos aleatórios de pessoas desconhecidas

SINTOMAS DE INFECÇÃO
- Lentidão ou Superaquecimento (EX: PC sempre fica em 100% de uso a todo momento)
- Alterações de sistema não autorizadas (EX: Antivírus foi desativado sozinho)
- Arquivos inacessíveis ou Indisponíveis (EX: Arquivos excluídos ou alterados sozinhos)

<5> EVOLUÇÃO DE ALGORITMOS DE WIFI

WEP (Wired Equivalent Privacy)
Obsoleto e extremamente fraco, Criptografia RC4.

Vulnerabilidade: Falhas no vetor de inicialização (IV) permitem que a senha seja quebrada em poucos minutos interceptando pacotes na rede.

WPA (Wi-Fi Protected Access)
Solução temporária (Quebra-galho histórico). Criptografia TKIP.

Vulnerabilidade: Criado para rodar em hardwares antigos, herdou falhas que o tornam vulnerável a ataques de injeção de pacotes.

WPA 2
O padrão atual mais comum no mundo. Criptografia AES (Criptografia forte de nível militar).

Vulnerabilidade: Vulnerável a ataques de força bruta ou dicionário offline (o atacante captura o 4-way handshake quando um usuário conecta e tenta adivinhar a senha no próprio computador).

WPA 3
O padrão moderno e definitivo. Criptografia: AES-GCMP e SAE (Simultaneous Authentication of Equals).

Segurança: Bloqueia ataques de dicionário offline (o invasor precisa interagir com o roteador a cada tentativa de senha) e protege a rede mesmo se a senha for fraca.